Política de Privacidade

Projeto de comércio eletrônico PavPlas

MINUTA PARA VALIDAÇÃO — NÃO PUBLICAR SEM PREENCHER OS CAMPOS E CONFIRMAR AS OPERAÇÕES REAIS.

Versão de trabalho • 4 de novembro de 2026

Conteúdo

1 Identificação e validade desta política 1
2 Quem somos e a quem esta política se aplica 1
3 Quais dados podemos tratar e para quê 1
4 Finalidades e bases legais 2
5 Com quem os dados podem ser compartilhados 2
6 Pagamentos e segurança financeira 3
7 Cookies e tecnologias semelhantes 3
8 Retenção e descarte 3
9 Direitos do titular 4
10 Dados de crianças e adolescentes 4
11 Atualizações e contato 4
12 Glossário 4
13 Referências normativas e orientativas 5

1 Identificação e validade desta política

Esta minuta descreve, em linguagem acessível, como a PavPlas pretende tratar dados pessoais em seu ambiente de comércio eletrônico, cadastro de clientes, pedidos e, quando ativado, pagamentos digitais. Ela foi preparada a partir do projeto acadêmico "Desenvolvimento e Implementação de um Gateway de Pagamento para a PavPlas". A própria monografia indica que o provedor de pagamento e algumas integrações ainda estão planejados. Por isso, este documento não afirma que essas operações já estejam em produção.

Antes de publicar, a empresa deve confirmar e preencher:

- **Controladora:** PavPlas [razão social completa].
- **CNPJ:** [preencher].
- **Endereço para correspondência:** [preencher].
- **Canal de privacidade e solicitações dos titulares:** [e-mail ou formulário oficial].
- **Encarregado pelo tratamento, se aplicável, ou canal designado:** [nome/canal].
- **Data de vigência e versão:** [preencher após aprovação].

2 Quem somos e a quem esta política se aplica

Para fins desta política, "PavPlas" designa a pessoa jurídica que decidir as finalidades e os meios essenciais do tratamento. A identificação formal da empresa deve ser completada nos campos acima. Quando a PavPlas definir por que e como os dados são tratados, atuará como controlador de dados pessoais (controlador). Prestadores contratados poderão atuar como operador de dados pessoais (operador), conforme as atividades e os contratos efetivamente realizados. A qualificação de cada fornecedor depende do papel que exerce em cada tratamento, não apenas do nome do contrato ou serviço.

Esta política destina-se a clientes e visitantes que utilizem o site, criem conta, consultem produtos, montem pedidos ou, após a ativação das integrações, concluam uma compra. Aplica-se também aos dados de contato e de entrega necessários à operação. Não substitui os termos de uso, avisos específicos no momento da coleta nem a política de cookies que deverá ser apresentada caso o site utilize cookies não essenciais.

3 Quais dados podemos tratar e para quê

A PavPlas deve solicitar apenas dados adequados e necessários à finalidade informada. Conforme o fluxo de compra descrito no projeto, as categorias podem incluir:

- **Cadastro e contato:** nome ou razão social, CPF/CNPJ quando necessário à operação fiscal, e-mail, telefone e dados de acesso à conta. Usados para identificar o cliente, atender solicitações e administrar a conta.
- **Pedido, cobrança e entrega:** produtos, quantidades, preços, descontos, frete, valor total, endereço de entrega e cobrança. Usados para formar o pedido, calcular ou contratar a entrega, acompanhar o atendimento e cumprir obrigações relacionadas à venda.
- **Registro da transação:** identificador do pedido e da transação, meio escolhido, valor, parcelas quando houver, datas, status e comprovantes ou referências do pagamento. Usados para acompanhar o pagamento, conciliar a venda, administrar cancelamentos e reembolsos e manter a rastreabilidade.
- **Dados técnicos e de segurança:** endereço IP, data e hora de acesso, identificadores de sessão e informações do navegador/dispositivo, quando efetivamente coletados. Usados para proteger contas

e serviços, diagnosticar falhas e investigar eventos de segurança, observadas a necessidade, a transparência e a base legal aplicável.

- **Atendimento e solicitações:** conteúdo das mensagens e informações necessárias à análise da solicitação, devolução, cancelamento ou reembolso.

O projeto prevê processamento de pagamentos por provedor externo, mas o fornecedor ainda precisa ser definido. A arquitetura proposta estabelece que o número completo do cartão, o código de segurança (CVV) e a validade não sejam armazenados no banco de dados local. A empresa deve confirmar essa arquitetura e o fluxo real com o fornecedor antes de disponibilizar o pagamento. Poderão ser mantidos identificadores e dados limitados de referência da transação, se necessários e confirmados, como token de referência, bandeira e últimos quatro dígitos. Não informe dados de cartão por e-mail, mensagem ou canal de atendimento.

4 Finalidades e bases legais

Os dados poderão ser tratados para: criar e administrar contas; responder a solicitações; preparar e executar pedidos; entregar produtos; processar ou acompanhar pagamentos por prestadores habilitados; realizar conciliação e reembolso; cumprir obrigações fiscais, consumeristas e outras obrigações legais; proteger os sistemas e prevenir operações irregulares; e exercer direitos em processos administrativos ou judiciais.

Cada atividade deve estar vinculada a uma hipótese legal adequada da Lei Geral de Proteção de Dados Pessoais (LGPD). Dependendo do contexto, isso pode incluir a execução de contrato ou procedimentos preliminares solicitados pelo cliente, o cumprimento de obrigação legal ou regulatória, o exercício regular de direitos, ou o legítimo interesse após avaliação de necessidade, expectativas e impactos sobre os titulares. Consentimento será solicitado quando for a hipótese aplicável, por exemplo, para finalidades opcionais que dele dependam. A base legal deve ser definida para cada finalidade concreta; esta lista não significa que todas as bases sejam usadas para todos os dados.

5 Com quem os dados podem ser compartilhados

O compartilhamento deve limitar-se ao necessário para as finalidades informadas, com medidas de segurança e obrigações contratuais compatíveis. Conforme as integrações efetivamente habilitadas, os destinatários poderão incluir:

- prestador de pagamento ou instituição financeira escolhida pela PavPlas, para gerar cobranças, processar pagamentos e devolver o status da transação;
- transportadoras, plataforma de cotação de frete e operadores logísticos, para calcular o frete e entregar o pedido;
- sistema de gestão empresarial/ERP, incluindo o Bling se a integração planejada for implementada, para registrar dados comerciais, financeiros e fiscais e apoiar a emissão de documentos fiscais;
- fornecedores de hospedagem, banco de dados, autenticação, suporte e segurança da aplicação, de acordo com os serviços efetivamente contratados;
- autoridades públicas ou terceiros, quando houver obrigação legal, ordem válida ou necessidade de exercício regular de direitos.

A monografia descreve hospedagem pretendida em Vercel, Render e Supabase, ERP Bling e integração de pagamentos ainda planejada. A empresa deve verificar quais fornecedores serão realmente contratados,

quais dados cada um recebe, seus papéis, subcontratados, localidades de armazenamento e mecanismos de transferência internacional, quando existentes. Nenhum fornecedor deve receber dados apenas porque aparece como opção técnica no projeto.

6 Pagamentos e segurança financeira

No checkout, o cliente poderá escolher entre os meios efetivamente disponibilizados. O projeto prevê Pix, boleto e cartão de crédito, mas sua disponibilidade dependerá da contratação e ativação do provedor. O status do pagamento poderá ser recebido por integração ou notificação eletrônica e associado ao pedido para atualização do fluxo de venda. A criação de uma cobrança, isoladamente, não significa que o pagamento foi confirmado.

A PavPlas deve adotar controles técnicos e organizacionais proporcionais ao risco, como limitação de acesso por função, proteção de credenciais, registro de operações administrativas, validação da origem das notificações de pagamento, cópias de segurança e correção de vulnerabilidades, conforme implantados e testados. O projeto descreve autenticação, controle de acesso por perfis e medidas para reduzir a exposição de dados financeiros; a organização deve validar a configuração real antes de declarar conformidade ou garantir um nível específico de segurança. Nenhuma transmissão ou armazenamento eletrônico pode ser descrito como absolutamente seguro.

7 Cookies e tecnologias semelhantes

Cookies estritamente necessários poderão ser utilizados para funções essenciais, como manter a sessão e proteger o acesso, se presentes na implementação. Cookies de análise, personalização ou publicidade só devem ser ativados após a PavPlas identificar as tecnologias utilizadas e oferecer informação clara e, quando exigido, escolha efetiva ao visitante. O usuário deve poder rever suas preferências por um mecanismo acessível. A empresa deve publicar uma lista atualizada de cookies, suas finalidades, duração e terceiros envolvidos, caso essas tecnologias sejam utilizadas. Não se afirma nesta minuta que o site atual emprega cookies de análise ou publicidade.

8 Retenção e descarte

Os dados serão mantidos pelo tempo necessário à finalidade para a qual foram coletados e, depois, eliminados ou anonimizados, ressalvadas as hipóteses de conservação previstas em lei ou necessárias ao exercício regular de direitos. Documentos fiscais e registros comerciais podem ter prazos legais próprios. Não se deve aplicar um único prazo indistintamente a todos os dados nem publicar prazos fixos antes de a empresa aprovar uma tabela de temporalidade que considere cada categoria, obrigação legal, necessidade operacional e eventual litígio.

Registros de acesso a aplicações e outros logs podem estar sujeitos a regras específicas do Marco Civil da Internet, conforme o tipo de registro e o papel de cada fornecedor. A PavPlas deve confirmar quais registros são coletados, quem os guarda e por quanto tempo. Ao fim do prazo aplicável, os dados devem ser eliminados ou anonimizados de forma segura, inclusive nas cópias de segurança conforme os ciclos técnicos de expurgo documentados.

9 Direitos do titular

Nos termos da LGPD, o titular dos dados pessoais (titular) pode solicitar, conforme aplicável: confirmação da existência de tratamento; acesso aos dados; correção de dados incompletos, inexatos ou desatualizados; anonimização, bloqueio ou eliminação de dados excessivos ou tratados em desconformidade; portabilidade, observadas as normas aplicáveis e os segredos comercial e industrial; informação sobre compartilhamentos; informação sobre a possibilidade de não consentir e consequências; e revogação do consentimento, quando o tratamento se basear nele. Também pode solicitar revisão de decisões tomadas unicamente com base em tratamento automatizado, nos termos legais.

As solicitações devem ser encaminhadas para [canal oficial de privacidade a preencher]. Para proteger a conta e evitar divulgação indevida, a PavPlas poderá verificar a identidade do solicitante de forma proporcional. A resposta observará os prazos, limites e procedimentos previstos na legislação. Alguns dados poderão ser conservados quando houver obrigação legal ou outra hipótese autorizadora, mesmo após pedido de exclusão; nesse caso, o uso será limitado à finalidade que justifica a conservação.

10 Dados de crianças e adolescentes

A loja não deve direcionar suas ofertas nem solicitar intencionalmente dados de crianças. Se a operação vier a envolver dados de crianças ou adolescentes, a PavPlas deverá avaliar previamente as exigências legais específicas e adotar as salvaguardas apropriadas. Responsáveis que identifiquem tratamento inadequado podem utilizar o canal de privacidade informado nesta política.

11 Atualizações e contato

Esta política poderá ser atualizada quando houver mudanças relevantes nas operações, nos fornecedores, nos meios de pagamento ou na legislação. A versão vigente deverá ficar acessível no site, com indicação da data de atualização. Mudanças relevantes que afetem a forma como os dados são tratados devem ser comunicadas de maneira apropriada.

Dúvidas ou solicitações sobre privacidade: [e-mail/formulário oficial]. Correspondência: [endereço da empresa]. Encarregado ou canal designado: [preencher conforme decisão e regras aplicáveis]. Se não ficar satisfeito com a resposta, o titular poderá buscar os canais competentes, inclusive a Autoridade Nacional de Proteção de Dados (ANPD), conforme cabível.

12 Glossário

controlador – **controlador de dados pessoais**: Agente que toma as decisões referentes às finalidades e aos elementos essenciais do tratamento.

LGPD – **Lei Geral de Proteção de Dados Pessoais**: Lei nº 13.709/2018, que estabelece regras para o tratamento de dados pessoais no Brasil.

operador – **operador de dados pessoais**: Agente que trata dados pessoais em nome do controlador.

titular – **titular dos dados pessoais**: Pessoa natural a quem se referem os dados pessoais tratados.

13 Referências normativas e orientativas

- BRASIL. **Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais**. Texto legal. Disponível em: https://www2.camara.leg.br/legin/fed/lei/2018/lei-13709-14-agosto-2018-787077-publicacaooriginal-156212-pl.html. Acesso em: 4 nov. 2026.
- AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. **Guia Orientativo para Definições dos Agentes de Tratamento de Dados Pessoais e do Encarregado**. Versão 2.0. Brasília, DF: ANPD, abr. 2022. Disponível em: https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/Segunda_Versao_do_Guia_de_Agentes_de_Tratamento_retificada.pdf/@@display-file/file. Acesso em: 4 nov. 2026.
- AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. **Guia Orientativo: Cookies e Proteção de Dados Pessoais**. Brasília, DF: ANPD, 2022, atualizado em 2025. Disponível em: https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/guia-orientativo-cookies-e-protecao-de-dados-pessoais.pdf. Acesso em: 4 nov. 2026.

Nota de uso: este documento é uma minuta informativa elaborada para o projeto acadêmico com base nas informações disponíveis na monografia. Não constitui parecer jurídico nem comprova conformidade legal ou técnica. Antes da publicação, a empresa deve confirmar o fluxo real de dados, fornecedores, prazos, bases legais, canais de atendimento e medidas de segurança, preencher os campos pendentes e submeter o texto à revisão jurídica e do responsável interno por privacidade.